



МИНОБРНАУКИ РОССИИ

Федеральное государственное бюджетное образовательное учреждение
высшего образования

«МИРЭА – Российский технологический университет»

РТУ МИРЭА

ЛЕКЦИОННЫЕ МАТЕРИАЛЫ

Системы мониторинга и управления инцидентами информационной безопасности

	<i>(наименование дисциплины (модуля) в соответствии с учебным планом)</i>
Уровень	
	<i>(бакалавриат, магистратура, специалитет)</i>
Форма обучения	
	<i>(очная, очно-заочная, заочная)</i>
Направление(-я) подготовки	
	<i>(код(-ы) и наименование(-я))</i>
Институт	Институт кибербезопасности и цифровых технологий
	<i>(полное и краткое наименование)</i>
Кафедра	Интеллектуальные системы информационной безопасности
	<i>(полное и краткое наименование кафедры, реализующей дисциплину (модуль))</i>
Лектор	к.т.н., Урасков Юрий Леонидович
	<i>(сокращенно – ученая степень, ученое звание; полностью – ФИО)</i>
Используются в данной редакции с учебного года	2022/23
	<i>(учебный год цифрами)</i>
Проверено и согласовано « ____ » _____ 20__ г.	
	<i>(подпись директора Института/Филиала с расшифровкой)</i>

Москва 2022 г.

Лекция 1. Термины и определения. Общие положения по мониторингу информационной безопасности

Мониторинг информационной безопасности в информационных (автоматизированных) системах представляет собой процесс постоянного наблюдения и анализа результатов регистрации событий безопасности с целью выявления нарушений, угроз безопасности информации и уязвимостей в информационных (автоматизированных) системах. Мониторинг информационной безопасности в информационной (автоматизированной) системе предусматривает выполнение следующих мероприятий:

- контроль за событиями безопасности и действиями пользователей в информационной (автоматизированной) системе;
- контроль (анализ) защищенности информации, содержащейся в информационной (автоматизированной) системе;
- анализ и оценка функционирования системы защиты информации информационной (автоматизированной) системы;
- периодический анализ изменения угроз безопасности информации в информационной (автоматизированной) системе, возникающих в ходе ее эксплуатации.

Есть проект ГОСТ Р (<https://fstec.ru/en/component/attachments/download/2438>)

Кроме того, при выполнении мероприятий необходимо руководствоваться следующими нормативными документами:

ГОСТ Р 50922-2006 Защита информации. Основные термины и определения.

ГОСТ Р 53114-2008 Защита информации. Обеспечение информационной безопасности в организации. Основные термины и определения.

ГОСТ Р Защита информации. Регистрация событий безопасности. Требования к регистрируемой информации.

Мониторинг информационной безопасности может осуществляться в рамках системы менеджмента информационной безопасности операторов информационных (автоматизированных) систем. При осуществлении мониторинга информационной безопасности в информационных (автоматизированных) системах могут использоваться соответствующие автоматизированные средства (дополнительные программные и программно-технические средства).

Основные понятия и определения.

Мониторинг информационной безопасности – процесс постоянного наблюдения и анализа результатов регистрации событий безопасности с

целью выявления нарушений безопасности информации, угроз безопасности информации и уязвимостей в информационных (автоматизированных) системах.

Событие безопасности (информационной) – зафиксированное состояние информационной (автоматизированной) системы, сетевого, телекоммуникационного, коммуникационного, иного прикладного сервиса или информационно-телекоммуникационной сети, указывающее на возможное нарушение безопасности информации, сбой средств защиты информации, или ситуацию, которая может быть значимой для безопасности информации.

Угроза (безопасности информации) – совокупность условий и факторов, создающих потенциальную или реально существующую опасность нарушения безопасности информации.

Уязвимость информационной (автоматизированной) системы – недостаток (слабость) информационной (автоматизированной) системы, который (которая) создает потенциальные или реально существующие условия для реализации или проявления угроз безопасности информации.

Фильтрация событий безопасности – выборка данных о событиях безопасности информации из состава данных, передаваемых для дальнейшего мониторинга информационной безопасности или долгосрочного хранения по определенным критериям (правилам) мониторинга информационной безопасности.

Агрегация – процесс объединения однородных данных о событиях безопасности или иных данных, получаемых в результате мониторинга информационной безопасности.

Информационная (автоматизированная) система – совокупность содержащейся в базах данных информации и обеспечивающих ее обработку информационных технологий и технических средств.

Корреляция событий безопасности – процесс выявления последовательности разнородных событий безопасности, имеющих логическую связь, которые могут быть значимы для выявления возможных нарушений безопасности информации.

Меры обеспечения информационной безопасности – совокупность действий, направленных на разработку и/или практическое применение способов и средств обеспечения информационной безопасности.

Объектами мониторинга в информационной (автоматизированной) системе являются:

- автоматизированные рабочие места;
- серверное оборудование;
- телекоммуникационное оборудование;
- технологическое и (или) производственное оборудование (исполнительные устройства);
- средства защиты информации.

Выделяются следующие **уровни мониторинга** информационной безопасности:

- уровень источников данных;
- уровень сбора данных;
- уровень хранения и обработки данных;
- уровень представления информации мониторинга потребителям.

Задачи мониторинга

В рамках мероприятий по мониторингу информационной безопасности в информационной (автоматизированной) системе должны быть решены следующие задачи:

В части мероприятий контроля за событиями безопасности и действиями пользователей в информационной (автоматизированной) системе:

- сбор данных о событиях безопасности от различных источников в информационной (автоматизированной) системе;
- нормализация, фильтрация и агрегация данных о событиях безопасности;
- корреляция событий безопасности с целью выявления нарушений безопасности информации;
- сопоставление событий безопасности с потоками данных об угрозах, содержащие индикаторы компрометации;
- контроль, учет и статистический анализ действий пользователей и администраторов информационной (автоматизированной) системы;
- сопоставление результатов регистрации событий безопасности с результатами анализа уязвимостей;
- выявление нарушений безопасности информации в информационной (автоматизированной) системе;
- информирование ответственных лиц о выявленных нарушениях безопасности информации.

В части мероприятий контроля (анализа) защищенности информации, содержащейся в информационной (автоматизированной) системе:

- выявление (поиск) уязвимостей в информационной (автоматизированной) системе;
- разработка по результатам выявления (поиска) уязвимостей отчетов с описанием выявленных уязвимостей и рекомендациями по их устранению;

- контроль установки обновлений программного обеспечения, включая программное обеспечение средств защиты информации;
- контроль состава технических средств, программного обеспечения и средств защиты информации, применяемых в информационной (автоматизированной) системе (инвентаризация);
- контроль соответствия настроек программного обеспечения и средств защиты информации установленным требованиям безопасности (политикам безопасности);
- контроль потоков информации;
- информирование ответственных лиц о результатах поиска уязвимостей, контроля установки обновлений программного обеспечения, контроля состава технических средств, программного обеспечения и средств защиты информации.

В части мероприятий анализа и оценки функционирования системы защиты информации информационной (автоматизированной) системы:

- контроль работоспособности (неотключении) программного обеспечения и средств защиты информации;
- проверка соответствия среды функционирования требованиям, предъявленным в документации на средства защиты информации;
- информирование о неисправностях, сбоях и отказах в функционировании программно-технических средств информационной (автоматизированной) системы.

В части мероприятий периодического анализа изменения угроз безопасности информации в информационной (автоматизированной) системе, возникающих в ходе ее эксплуатации:

- получение данных о новых угрозах безопасности информации, из доступных источников, содержащих сведения об уязвимостях и угрозах безопасности информации;
- оценка актуальности для информационной (автоматизированной) системы новых угроз безопасности информации и определение рекомендаций по принятию мер защиты, направленных на нейтрализацию новых угроз безопасности информации.

Классификация технических средств мониторинга ИБ.

Описание процесса сбора и обработки сведений в реальном времени.

Основные компоненты ИАС мониторинга.

Основные источники сведений системы мониторинга.

DLP-системы, IDS-системы, журналы событий домена.

Достоинства и недостатки.